SECURITY ASSESSMENT



AYUSH KUMAR JHA

26.01.2025

Section 1:
Integrating SDLC

Transitioning to Secure SDLC

Requirements Analysis
• Conduct user interviews to gather functional requirements. • Write a requirements document for task management features. **<u>Additional Security Task:-</u>** 1. Perform risk analysis to identify high-priority risks and align requirements accordingly. 2. Identify security requirements, such as data encryption, authentication, and authorization, and document them in the requirements.
Design
• Create a high-level architecture diagram for the application. • Design the database schema for tasks. **<u>Additional Security Task:-</u>** 1. Conduct a design review focusing on security, ensuring key design decisions are validated by security experts. 2. Define and document secure authentication and authorization mechanism.

Transitioning to Secure SDLC

Development
• Code the user interface using HTML and CSS. • Implement interactive elements using JavaScript. • Set up a Flask application to handle API requests. • Implement CRUD operations for tasks. **Additional Security Task:-** 1. Use static application security testing tools to identify vulnerabilities in the codebase during development. 2. Implement input validation libraries to prevent injection attacks, ensuring all user inputs are sanitized.
Testing
• Write and execute functional test cases. Conduct browser compatibility testing. **Additional Security Task:** 1. Conduct security regression testing to ensure new changes don't introduce previously revolved vulnerabilities 2. Conduct penetration testing and validate that the application is resilient against common vulnerabilities such as XSS, SQL

Transitioning to Secure SDLC

Deployment

- Deploy the application to Heroku.
- Perform smoke testing on the deployed applications.

Additional Security Tasks:-

1. Conduct an audit of third-party services for compliance with your security policies.
2. Set up automated tools for monitoring the security status of production environments, such as cloud configuration analysis tools.

Maintenance

- Monitor application logs and fix reposted issues.
- Gather user feedback for future feature additions.

Additional Security Task:-

1. Implement a vulnerability management process to regularly scan the application and dependencies for security updates and patches.
2. Establish a bug bounty program to incentivize external researchers to report vulnerabilities

Advocating for Secure SDLC

1. Protective Security Integration
Secure SDLC integrates security measures at every stage of development to identify and address vulnerabilities early. This minimizes the risk of costly post-deployment fixes and protects sensitive user data and cryptocurrency transactions.
2. Enhanced Flexibility and Responsiveness
Unlike the rigid Waterfall model, Secure SDLC supports iterative development. This agility allows the team to adapt quickly to security threats and regulatory changes, ensuring our platform remains compliant and resilient.
3. Continuous Risk Management
Secure SDLC emphasizes ongoing risk assessments and threat modeling, ensuring potential attack vectors are identified and mitigated throughout the project lifecycle. This is crucial in safeguarding the platform's reputation and user trust.
4. Improved Collaboration Across Teams
Secure SDLC fosters collaboration between developers, security professionals, and operations teams, breaking down silos. This ensures that security becomes a shared responsibility, resulting in a more robust and secure platform
5. Cost Efficiency and Reduced Downtime
Addressing security issues during development is significantly cheaper than fixing them after deployment. Secure SDLC reduces the likelihood of breaches, minimizing downtime and financial losses while maintaining platform reliability for our 1 million+ users

Section 2:
Vulnerabilities and Remediation

Vulnerabilities and remediation

1. BRUTE FORCE ATTACKS
Description
Login systems without adequate protections can allow unlimited login attempts, enabling attackers to systematically try passwords until they succeed
Risk
Some of the risks are:- • *Unauthorized access to accounts.* • *Potential lockout of legitimate users if attackers trigger account lacking mechanism maliciously.* • *Higer system load due to the volume of login attempts.*
Remediation
1. *Limit the number of login attempts from a single IP address within a specific time window.* 2. *Use CAPTCHAs after several failed attempts to distinguish bots from humans.* 3. *Increase the delay between login attempts after repeated failures.* 4. *Track and alert on unusual patterns.* 5. *Lock account temporarily after a set number of failed attempts but inform users through email about suspicious activity.* 6. *Implementing MFA as even if the attackers guess the passwords, MFA can act as an additional barrier access.*

Vulnerabilities and remediation

2. FAILURE TO IMPLEMENT HTTPS
Description
Login pages served over HTTP instead of HTTPS expose credentials to interception during transmission through man-in-the-middle attacks
Risk
• *Attackers can capture login credentials in plaintext, leading to unauthorized access.* • *User trust is diminished due to insecure communication.*
Remediation
1. *Redirect all HTTP traffic to HTTPS using strict transport security.* 2. *Ensure the server supports only modern, secure versions of TLS.* 3. *Regularly test and disable outdated ciphers to maintain secure communication.* 4. *Use certificates from trusted Certificate Authorities and renew them before expiration.*

Vulnerabilities and remediation

3. VULNERABLE SESSION MANAGEMENT
Description
Improper session management can expose sessions to hijacking through methods such as stealing cookies or session fixation.
Risk
• *Attackers can impersonate users by hijacking their active sessions.* • *Unauthorized access to sensitive information or administrative actions.* • *Increased attack surface for privilege escalation.*
Remediation
1. *Automatically log users out after a period of inactivity* 2. *Invalidate sessions upon logout or when changing passwords.* 3. *Rotate session tokens periodically during active sessions.* 4. *Generate cryptographically secure, random tokens with sufficient entropy.*

Threat Matrix

Pathway (Vulnerability)	Impact Level	Likelihood Level
Brute Force Attacks	Medium	High
Failure to Implement HTTPS	High	High
Vulnerable session Management	Medium	Medium

Fill out the matrix table. Impact levels are horizontal, and likelihood levels at the vertical axis.

Impact / Likelihood	Low	Medium	High
High		Brute Force Attacks	Failure to Implement HTTPS
Medium		Vulnerable Session Management	
Low			

Section 3:
Container Security

Project Information Slide

Trivy scan screenshot

```
┌──(ayush㉿kali)-[~]
└─$ trivy image --severity CRITICAL vulnerables/cve-2014-6271
2025-01-25T06:12:07-05:00    INFO    [vuln] Vulnerability scanning is enabled
2025-01-25T06:12:07-05:00    INFO    [secret] Secret scanning is enabled
2025-01-25T06:12:07-05:00    INFO    [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2025-01-25T06:12:07-05:00    INFO    [secret] Please see also https://aquasecurity.github.io/trivy/dev/docs/scanner/secret#recommendation for faster secret detection
2025-01-25T06:12:10-05:00    INFO    Detected OS    family="debian" version="7.11"
2025-01-25T06:12:10-05:00    INFO    [debian] Detecting vulnerabilities...    os_version="7" pkg_num=118
2025-01-25T06:12:10-05:00    INFO    Number of language-specific files    num=0
2025-01-25T06:12:10-05:00    WARN    Using severities from other vendors for some vulnerabilities. Read https://aquasecurity.github.io/trivy/dev/docs/scanner/vulnerability#severity-selecti
2025-01-25T06:12:10-05:00    WARN    This OS version is no longer supported by the distribution    family="debian" version="7.11"
2025-01-25T06:12:10-05:00    WARN    The vulnerability detection may be insufficient because security updates are not provided

vulnerables/cve-2014-6271 (debian 7.11)

Total: 47 (CRITICAL: 47)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
apache2	CVE-2018-1312	CRITICAL	fixed	2.2.22-13+deb7u12	2.2.22-13+deb7u13	httpd: Weak Digest auth nonce generation in mod_auth_digest https://avd.aquasec.com/nvd/cve-2018-1312
apache2-mpm-worker						
apache2-utils						
apache2.2-bin						
apache2.2-common						
bash	CVE-2014-6271			4.2+dfsg-0.1	4.2+dfsg-0.1+deb7u1	bash: specially-crafted environment variables can be used to inject shell commands https://avd.aquasec.com/nvd/cve-2014-6271
	CVE-2014-7169				4.2+dfsg-0.1+deb7u3	bash: code execution via specially-crafted environment (incomplete fix for CVE-2014-6271) https://avd.aquasec.com/nvd/cve-2014-7169
gcc-4.7-base	CVE-2014-5044		affected	4.7.2-5		gcc: integer overflow flaws in libgfortran https://avd.aquasec.com/nvd/cve-2014-5044
libc-bin	CVE-2014-9761			2.13-38+deb7u12		glibc: Unbounded stack allocation in nan* functions https://avd.aquasec.com/nvd/cve-2014-9761
	CVE-2018-6485		will_not_fix			glibc: Integer overflow in posix_memalign in memalign functions https://avd.aquasec.com/nvd/cve-2018-6485
libc6	CVE-2014-9761					glibc: Unbounded stack allocation in nan* functions https://avd.aquasec.com/nvd/cve-2014-9761
	CVE-2018-6485					glibc: Integer overflow in posix_memalign in memalign functions https://avd.aquasec.com/nvd/cve-2018-6485
libexpat1	CVE-2016-9063		affected	2.1.0-1+deb7u5		firefox: Possible integer overflow to fix inside XML_Parse in Expat https://avd.aquasec.com/nvd/cve-2016-9063
libgcc1	CVE-2014-5044			1:4.7.2-5		gcc: integer overflow flaws in libgfortran https://avd.aquasec.com/nvd/cve-2014-5044
libgnutls26	CVE-2017-5336			2.12.20-8+deb7u5		gnutls: Stack overflow in cdk_pk_get_keyid https://avd.aquasec.com/nvd/cve-2017-5336
	CVE-2017-5337					gnutls: Heap read overflow in read-packet.c https://avd.aquasec.com/nvd/cve-2017-5337
libncurses5	CVE-2017-10684			5.9-10		ncurses: Stack-based buffer overflow in fmt_entry function in dump_entry.c https://avd.aquasec.com/nvd/cve-2017-10684
	CVE-2017-10685					ncurses: Stack-based buffer overflow caused by format string vulnerability in fmt_entry function ... https://avd.aquasec.com/nvd/cve-2017-10685
libncursesw5	CVE-2017-10684					ncurses: Stack-based buffer overflow in fmt_entry function in dump_entry.c https://avd.aquasec.com/nvd/cve-2017-10684
	CVE-2017-10685					ncurses: Stack-based buffer overflow caused by format string vulnerability in fmt_entry function ...
libpcre3	CVE-2015-5073			1:8.30-5		pcre: buffer overflow for forward reference within backwo assertion with excess closing ... https://avd.aquasec.com/nvd/cve-2015-5073
	CVE-2015-8390					pcre: uninitialized memory read triggered by malformed posix character class (8.38/22) https://avd.aquasec.com/nvd/cve-2015-8390
	CVE-2015-8391					pcre: inefficient posix character class syntax check (8.38/16) https://avd.aquasec.com/nvd/cve-2015-8391
	CVE-2015-8394					pcre: Integer overflow caused by missing check for certain conditions (8.38/31) https://avd.aquasec.com/nvd/cve-2015-8394
	CVE-2016-3191					pcre: workspace overflow for (*ACCEPT) with deeply nested parentheses (8.39/33, 10.22/12) https://avd.aquasec.com/nvd/cve-2016-3191
libprocps0	CVE-2018-1126		fixed	1:3.3.3-3	1:3.3.3-3+deb7u1	procps: incorrect integer size in proc/alloc.* leading to truncation / integer overflow ... https://avd.aquasec.com/nvd/cve-2018-1126
libsqlite3-0	CVE-2017-2518		affected	3.7.13-1+deb7u4		An issue was discovered in certain Apple products. iOS before 10.3.2 i... https://avd.aquasec.com/nvd/cve-2017-2518
libstdc++6	CVE-2014-5044			4.7.2-5		gcc: integer overflow flaws in libgfortran https://avd.aquasec.com/nvd/cve-2014-5044
libtinfo5	CVE-2017-10684			5.9-10		ncurses: Stack-based buffer overflow in fmt_entry function in dump_entry.c https://avd.aquasec.com/nvd/cve-2017-10684
	CVE-2017-10685					ncurses: Stack-based buffer overflow caused by format string vulnerability in fmt_entry function ... https://avd.aquasec.com/nvd/cve-2017-10685
login	CVE-2017-12424			1:4.1.5.1-1+deb7u1		shadow-utils: Buffer overflow via newusers tool https://avd.aquasec.com/nvd/cve-2017-12424
multiarch-support	CVE-2014-9761			2.13-38+deb7u12		glibc: Unbounded stack allocation in nan* functions https://avd.aquasec.com/nvd/cve-2014-9761
	CVE-2018-6485		will_not_fix			glibc: Integer overflow in posix_memalign in memalign functions https://avd.aquasec.com/nvd/cve-2018-6485
ncurses-base	CVE-2017-10684		affected	5.9-10		ncurses: Stack-based buffer overflow in fmt_entry function
	CVE-2017-10685					ncurses: Stack-based buffer overflow caused by format string vulnerability in fmt_entry function ... https://avd.aquasec.com/nvd/cve-2017-10685
ncurses-bin	CVE-2017-10684					ncurses: Stack-based buffer overflow in fmt_entry function in dump_entry.c https://avd.aquasec.com/nvd/cve-2017-10684
	CVE-2017-10685					ncurses: Stack-based buffer overflow caused by format string vulnerability in fmt_entry function ... https://avd.aquasec.com/nvd/cve-2017-10685
passwd	CVE-2017-12424			1:4.1.5.1-1+deb7u1		shadow-utils: Buffer overflow via newusers tool https://avd.aquasec.com/nvd/cve-2017-12424
perl	CVE-2018-6797		will_not_fix	5.14.2-21+deb7u5		perl: heap write overflow in regcomp.c https://avd.aquasec.com/nvd/cve-2018-6797
	CVE-2018-6913		fixed		5.14.2-21+deb7u6	perl: heap buffer overflow in pp_pack.c https://avd.aquasec.com/nvd/cve-2018-6913
perl-base	CVE-2018-6797		will_not_fix			perl: heap write overflow in regcomp.c https://avd.aquasec.com/nvd/cve-2018-6797
	CVE-2018-6913		fixed		5.14.2-21+deb7u6	perl: heap buffer overflow in pp_pack.c https://avd.aquasec.com/nvd/cve-2018-6913
perl-modules	CVE-2018-6797		will_not_fix			perl: heap write overflow in regcomp.c https://avd.aquasec.com/nvd/cve-2018-6797
	CVE-2018-6913		fixed		5.14.2-21+deb7u6	perl: heap buffer overflow in pp_pack.c https://avd.aquasec.com/nvd/cve-2018-6913
procps	CVE-2018-1126			1:3.3.3-3	1:3.3.3-3+deb7u1	procps: incorrect integer size in proc/alloc.* leading to truncation / integer overflow ... https://avd.aquasec.com/nvd/cve-2018-1126
zlib1g	CVE-2016-9841		affected	1:1.2.7.dfsg-13		zlib: Out-of-bounds pointer arithmetic in inffast.c https://avd.aquasec.com/nvd/cve-2016-9841
	CVE-2016-9843					zlib: Big-endian out-of-bounds pointer https://avd.aquasec.com/nvd/cve-2016-9843

Report to Fix Container Issues

Vulnerability Name	Unpatched Software Version	Patched Software Version
CVE-2014-6271	Bash 4.3 and version before that	Bash 4.3.30
CVE-2021-3156	Sudo 1.8.31 and earlier versions	Sudo 1.9.5p2
CVE-2020-14368	Linux Kernel 5.7.7	Linux Kernel 5.8
CVE-2021-44228	Log4j 2.14.1	Log2j 2.16.0 or newer versions
CVE-2018-15664	Docker 18.06.1	Docker 18.09.2
CVE-2020-8554	Kubernetes 1.18	Kubernetes 1.19.16,1.20.12
CVE-2017-5638	Apache Struts 2.3.31	Apache Struts 2.5.10.1

Section 4:
API Security

Vulnerabilities and remediation

1. LACK OF RATE LIMITING AND THROTTLING
Description
APIs without proper rate-limiting allow attackers or malicious third-party vendors to send excessive requests to the server. This could lead to API abuse, data scraping, or denial-of service[DoS] attacks
Risk
• *Overloading the API server, resulting n degraded performance or downtime.* • *Unauthorized bulk data extraction by malicious actors or untrustworthy vendors.* • *Higher infrastructure costs due to increased server usage.*
Remediation
1. *Setting limits on the number of requests a client can make within a given timeframe* 2. *Temporarily block or delete requests from clients exceeding their usage quota to prevent service disruption.* 3. *Use API gateway or monitoring tools to track API usage patterns and detect abuse*

Vulnerabilities and remediation

2. INADEQUATE AUTHENTICATION MECHANISM
Description
APIs that do not enforce robust authentication mechanisms are vulnerable to unauthorized access
Risk
• *Unauthorized third-party access to sensitive user data.* • *Increased risk of brute force or credential stuffing attacks.* • *Loss of user trust and potential compliance violations.*
Remediation
1. *Requirement of additional verification steps for sensitive API endpoints.* 2. *Ensuring that access tokens have short lifespans and are rotated regularly.* 3. *Encrypting and securely storing API keys by using environmental variables instead of hardcoding keys in code.*

Vulnerabilities and remediation

3. BROKEN OBJECT LEVEL AUTHORIZATION
Description
BOLA occurs when the API fails to enforce proper access controls, allowing users to access or manipulate objects that they are not authorized to access
Risk
• *Exposure of sensitive user data to unauthorized data.* • *Breach of confidentiality, violating user trust and regularly compliance.* • *Potential misuse of data by unauthorized third-party vendors.*
Remediation
1. *Enforcing strict authorization that checks for every request at the object level. Verifying that only the authenticated user has access to the specific object they are requesting.* 2. *Avoid exposing sensitive identifiers like user IDs by using opaque references that are harder to guess.* 3. *Defining and enforcing roles and permissions for accessing different API endpoints and objects.*